Waysim — техническое задание

Oct 3, 2026 · @Hello Baby

1. Общие сведения

Waysim — приложение для iOS и Android по продаже туристических eSIM с внутренним балансом, плюс бэкенд и веб-админка. Waysim работает как реселлер: клиент покупает пакет с баланса в приложении, а бэкенд серверным запросом покупает eSIM у поставщика за счёт предоплаченного баланса Waysim и отдаёт её клиенту. Закупочная цена, маржа и ключи клиенту не видны никогда. Домен — waysim.co.

1.1 Команда и стек

Часть	Стек	Кто делает
Мобильное приложение	Flutter, Dart, Riverpod, go_router, dio, Firebase (Cloud Messaging, Crashlytics, App Check)	Мобильный разработчик (Flutter)
Бэкенд API	Node.js + TypeScript, Express (или NestJS), PostgreSQL, Redis, BullMQ, Docker, NGINX	Full-stack разработчик
Админ-панель	Next.js + TypeScript	Full-stack разработчик
ИИ-чат поддержки	LLM API (OpenAI или Claude) через бэкенд	Full-stack разработчик

- TypeScript на бэкенде обязателен: код работает с деньгами, строгая типизация убирает целый класс ошибок.
- Админку можно сделать и на Flutter Web силами мобильного разработчика, если так удобнее распределить нагрузку. Решение — на этапе 0.

1.2 Термины

- **Пакет** — страна или регион, объём (ГБ или безлимит), срок, цена. Местный — одна страна, региональный — несколько.
- **Баланс** — внутренний счёт клиента в USD; пополняется и тратится только в приложении, не выводится.
- **Гость** — установил приложение, но не зарегистрировался.

- **Админ, оператор** — роли сотрудников в админке.

2. Архитектура

Бэкенд — модульный монолит на Node.js: один сервис с независимыми модулями, которые при росте можно вынести отдельно. Приложение и админка ходят только в наш API, внешние сервисы подключены через адаптеры.

- **Модули:** auth, users, catalog, wallet (баланс и журнал денег), orders, payments, referrals, notifications, support-ai, admin, monitoring.
- **API без состояния:** сессии и кэш — в PostgreSQL и Redis, масштабирование копиями за NGINX.
- **Фоновые задачи** — запросы к поставщику, вебхуки, рассылки, синхронизация расхода — в очереди BullMQ; воркеры масштабируются отдельно.
- **Контракт:** REST + JSON, версия `/v1`, спецификация OpenAPI 3 в репозитории. Из неё генерируются клиент на Dart для приложения и на TypeScript для админки.
- **Адаптеры:** `ESimProvider` (первая реализация — основной поставщик, позже — резервный второй), `PaymentProvider` (PayPal, крипто-процессинг), `PushSender` (FCM), `EmailSender`, `LLMProvider`. У каждого пакета в каталоге указан его поставщик.
- База и Redis недоступны из интернета, статика (флаги, баннеры) отдаётся через CDN.



Ключи поставщика и платёжек хранятся только на сервере; вебхуки принимаются только с проверкой подписи.

архитектура Waysim · клиенты, API, данные, внешние сервисы

Приложение и админка обращаются только к нашему API; поставщик eSIM, платёжки, почта, push и ИИ подключены к бэкенду через адаптеры.

3. Дизайн и интерфейс

Стиль: тёмно-синий акцент, много белого, широкие жирные заголовки, мягкие тени. Цвета и компоненты заданы ниже, дизайнер рисует все экраны в Figma в светлой и тёмной теме.

Токен	Светлая (по умолчанию)	Тёмная
primary / primaryPressed	#2F4E8F / #26406F	#4A6CB8 / #3D5A9C
primarySubtle	#EAEFF8	#1C2740
link	#2F4E8F	#8FA9E0
background / surface	#FFFFFF / #F5F7FA	#0E121A / #161B25
textPrimary / textSecondary	#161D2B / #667085	#F2F4F8 / #98A2B3
textOnPrimary	#FFFFFF	#FFFFFF
border	#E3E8EF	#2A3242
error / errorSubtle	#D92D20 / #FEF3F2	#F97066 / #3A1714

Токен	Светлая (по умолчанию)	Тёмная
success / warning	#12855A / #B54708	#3CCB8A / #F79009

Тёмные значения — предложение; проверить контраст по WCAG AA (не меньше 4,5:1 для текста).

- **Во Flutter:** токены — в `ThemeExtension`, две `ThemeData` (светлая и тёмная). В виджетах только токены, никаких цветов и размеров напрямую.
- **Текст:** display, h1–h3 (широкий шрифт заголовков), body, bodyMedium, bodySmall, caption. Оба шрифта обязаны содержать кириллицу.
- **Компоненты:** Button (primary, secondary, ghost × sm, md, lg + disabled и loading), Input, Card, а также нижний лист, переключатель вкладок, строка страны с флагом, карусель, статус-бейдж, toast, пустое состояние, скелетоны, поле OTP из 6 ячеек, плавающая кнопка, таб-бар.
- **Языки:** `flutter gen-l10n`, файлы ARB en и ru, английский по умолчанию. Текста в коде нет.
- Флаги — SVG-набор в приложении, не эмодзи. Зоны нажатия не меньше 44 pt, учтены безопасные зоны, увеличенный системный шрифт не ломает вёрстку, анимации 200–300 мс.

4. Мобильное приложение

Три вкладки — Главное, Мои eSIM, Профиль — и плавающая кнопка поддержки на всех экранах. Без регистрации доступны каталог, поиск, настройки, документы и поддержка; покупка, пополнение, реферalка и заказы — после входа, с возвратом туда, где был человек.

4.1 Общие элементы

- **Кнопка поддержки:** круг 56 pt справа внизу над таб-баром, поднимается над закреплёнными кнопками «Купить» и «Пополнить». Открывает лист: «Онлайн-чат с ИИ» и «Написать нам».
- **Состояния:** скелетоны при загрузке, ошибка с кнопкой «Повторить», плашка «Нет подключения»; каталог и список eSIM показываются из кэша. Потянуть вниз — обновить.
- **Ссылки:** `https://waysim.co/...` (Universal Links и App Links) и `waysim://` через go_router — приглашения, возврат из оплаты, переходы из push. Параметры проверяются, ссылка не выполняет действий без подтверждения.

4.2 Главное

- **Шапка:** «Привет, {Имя}!» (без имени — «Привет!») и баланс, который ведёт в пополнение. У гостя вместо баланса — «Войти».
- **Поиск** «Где вам нужен eSIM?» (EN: «Where do you need an eSIM?»): мгновенный, по каталогу в кэше, с первой буквы; русские и английские названия, синонимы, коды стран («США», «USA», «US»). В результатах страны и регионы с «от $X», последние запросы сохраняются.
- **3 квадратных баннера:** свайп и автопрокрутка каждые 5 с по кругу, пауза при касании, контент и действия приходят с сервера. 1 — что такое eSIM (открывает «Принцип работы»), 2 — «Пригласите друга — получите $X» (сумма из настроек; ведёт в рефералку, при выключенной программе баннера нет), 3 — удобство в поездке (список «Местные»).
- **«Местные / Региональные»:** переключатель со списком ниже, по умолчанию «Местные». Страны — по алфавиту, с флагом и «от $X». Регионы — Европа, Азия, Америки, Африка, Ближний Восток, Океания, Весь мир (по пакетам поставщика). Без пакетов не показываются.

4.3 Страна и покупка

- **Совместимость:** «Устройство поддерживает eSIM: Да / Нет». Android — platform channel на Kotlin к `EuiccManager.isEnabled`; iOS — модель через `device_info_plus` и список совместимых моделей с сервера. Не определилось — ссылка на инструкцию. При «Нет» покупка возможна после предупреждения.
- **Пакеты:** вкладки «Безлимитные» и «С лимитом ГБ» (пустая скрыта), сортировка по цене: объём, дни, цена.
- **Выбранный пакет:** снизу «Сведения о пакете» (лист с прокруткой, тексты RU/EN с сервера), «Купить за $X» и подпись «Размещая заказ, вы подтверждаете, что используемое устройство совместимо с eSIM и не привязано к оператору».
- **Регион:** то же самое плюс раскрывающийся список стран пакета.
- **Покупка:** гость — сначала вход, потом обратно к пакету. Окно подтверждения: пакет, цена, баланс до и после. Не хватает денег — «Пополнить баланс» с подставленной суммой и возвратом к покупке. Приложение отправляет только ID пакета и ключ идемпотентности. Экран «Оформляем eSIM…»; дольше 30 с — «пришлём уведомление». Сбой поставщика — деньги автоматически возвращаются на баланс.

4.4 Мои eSIM

- **Пусто или гость:** кнопка «Принцип работы eSIM» (лист из 4 шагов: выбор, оплата с баланса, установка до поездки по QR или в одно нажатие, включение eSIM и роуминга данных по прилёте) и кнопка «Приобрести eSIM», которая ведёт на Главное.
- **Список:** флаг или регион, пакет, статус (Не установлена, Установлена, Активна, Израсходована, Истекла, Не выполнен), остаток трафика, срок, устройство. Израсходованные и истёкшие — в «Архиве».
- **Карточка eSIM:** QR (`qr_flutter`), адрес SM-DP+ и код активации с «Скопировать»; на iOS 17.4+ — установка в одно нажатие через Universal Link Apple; инструкции для iOS и Android; расход и «обновлено N мин назад»; предупреждение не удалять eSIM. Один пакет — одно устройство: привязка при нажатии «Установить».

4.5 Профиль и вход

- **Гость:** «Зарегистрироваться» (или «Войти», если на этом устройстве уже входили), ниже «Настройки» и «Подробнее».
- **Вход только по коду на почту:** почта и согласие с условиями (новым — поле «Код приглашения») → 6-значный код, вставка из буфера, повтор через 60 с → новым — необязательный шаг «Как к вам обращаться?». Ответ сервера одинаков для новых и существующих адресов.
- **Сессия без повторного входа:** access-токен около 15 минут, refresh-токен в `flutter_secure_storage` (Keychain и Keystore), новый при каждом обновлении. Сессия истекает только после 180 дней без открытия приложения.
- **После входа:** почта, баланс, ID вида «A0123» с копированием. Пункты: Мои устройства, Настройки (язык English/Русский, тема светлая/тёмная, уведомления), Пополнить баланс, Заказы (покупки и пополнения), Пригласить друзей, Подробнее (6 документов с waysim.co и «О приложении»), Удалить аккаунт (обязательно для App Store, подтверждение кодом), Выйти.

4.6 Баланс и пополнение

- Баланс в USD, хранится на сервере в центах, вывести нельзя. Суммы $10, $20, $50, $100 или своя (лимиты на сервере, предложение — от $5 до $500).
- **PayPal:** заказ создаёт сервер, оплата — во встроенном браузере (SFSafariViewController и Custom Tabs через `url_launcher`), зачисление после списания (capture) и проверки на сервере. Возвраты и споры приходят вебхуками и списывают баланс.

- **Криптовалюта:** инвойс у процессинга — сеть, адрес, сумма, QR, таймер; статусы «Ожидаем → Подтверждения N из M → Зачислено». Недоплата, переплата и поздняя оплата — «На проверке» в админке.
- Одна оплата зачисляется ровно один раз; после зачисления — push и возврат к покупке.

4.7 Поддержка и push

- **ИИ-чат:** через бэкенд, ключ только на сервере; модель OpenAI или Claude через адаптер `LLMProvider`. Системный промпт и база знаний RU/EN (FAQ передаёт заказчик). Отвечает только про Waysim и eSIM, не меняет баланс и не обещает возвраты, не видит почту и платежи; если не помог — предлагает «Написать нам». Около 30 сообщений в сутки, до 2000 символов, история 30 дней, пометка «Отвечает ИИ».
- **«Написать нам»:** `mailto:` на почту поддержки с темой «Waysim — обращение, ID A0123» и техническими данными; без почтового приложения — адрес с копированием. По условиям поставщика жалобы клиентов бренда обрабатываем мы, почта работает 24/7.
- **Push** через Firebase Cloud Messaging (на iOS — через APNs). Разрешение спрашиваем после первой покупки. Переключатель в настройках выключает все push, текст на языке приложения, нажатие открывает нужный экран.
- **События:** eSIM готова; заказ не выполнен и деньги вернулись; баланс пополнен; бонус начислен; осталось 100 МБ или меньше и остался 1 день (по вебхукам поставщика); пакет закончился; рассылка из админки.

4.8 Реферальная программа

- Экран «Пригласить друзей» (из баннера и профиля): код из 6–8 случайных символов, ссылка `waysim.co/r/КОД`, «Поделиться», статистика (приглашено, начислено, на проверке, отклонено).
- Код вводится только при первой регистрации (по ссылке подставляется сам). Бонус на баланс (сумма задаётся в админке, по умолчанию $3) получает пригласивший; тратится только на пакеты, админ может отменить бонус обратной записью.
- **Проверки** — не пройдена любая, приглашение «Отклонено» или «На проверке»: устройство (Firebase App Check — App Attest на iOS, Play Integrity на Android; одно устройство — один бонус навсегда); эмуляторы, root и jailbreak; IP (не совпадает с IP пригласившего за 30 дней, лимит регистраций с одного

IP или подсети в сутки, VPN и дата-центры — «На проверке»); одноразовые почты запрещены, адреса нормализуются; не больше 10 бонусов в месяц на пригласившего.

Когда начисляется бонус:

- По умолчанию — сразу после того, как друг зарегистрировался по коду и прошёл все проверки выше.
- Момент начисления — настройка в админке (раздел 6.6): «после регистрации» или «после первой покупки друга». Второй вариант заметно сложнее абузить (раздел 9).

Если программа выключена в админке, в приложении не показываются баннер №2, пункт профиля «Пригласить друзей», поле «Код приглашения» при регистрации и push о бонусах; карусель показывает оставшиеся баннеры. Сумма бонуса во всех текстах подставляется из настроек сервера, а не вшита в приложение. Настройки (`referral.enabled`, `referral.rewardCents`) приложение получает при запуске и при возврате на экран.

5. Бэкенд

Каждый пользователь, даже гость, получает публичный ID вида A0000. Деньги двигаются только через журнал записей в транзакциях базы, а заказы у поставщика идут из фоновых задач с автоматическим возвратом денег при сбое.

5.1 ID пользователей

- ID выдаётся при первом запуске приложения (гость) и сохраняется при регистрации. Если на устройстве входят в существующий аккаунт, гостевая запись объединяется с ним и перестаёт считаться незарегистрированной. При переустановке устройство по возможности узнаётся.
- **Формат:** A0000…A9999, затем B0000…Z9999 — всего 260 000 ID. Из последовательности в базе: буква = A + ⌊n / 10000⌋, цифры = n mod 10000 с ведущими нулями. Без повторов, удалённые ID не переиспользуются.
- Внутренний ключ — UUID. Права доступа по публичному ID не проверяются.

5.2 Данные

Полная схема — на этапе 0. Ключевые сущности: users, devices, sessions, otp_codes, wallets и ledger_entries (журнал денег), payments с деталями крипто-платежей и PayPal, countries и regions, packages (поставщик, артикул, тип, объём, дни, розничная и закупочная цена, описания RU/EN, статус и порядок показа),

orders, esims (ICCID, SM-DP+, зашифрованный код активации, статус, расход), referrals, broadcasts, admin_users, audit_log, app_config (баннеры, совместимые модели, документы, база знаний ИИ, лимиты, настройки реферальной программы, порог маржи и наценка по умолчанию).

5.3 Деньги

- Все суммы — целые центы USD, без чисел с плавающей точкой.
- Каждое изменение баланса — запись в журнале внутри транзакции с блокировкой строки баланса. Покупка не может увести баланс в минус.
- Цена берётся только из базы. Заказы и пополнения принимают ключ идемпотентности. Закупочная цена и маржа не попадают в ответы API для приложения.
- Ежедневная сверка: оплаты против журнала, наши заказы против заказов у поставщика. Расхождение — уведомление админу.

5.4 Как работает API поставщика

Поставщик — оптовая eSIM-платформа с собственным сервером SM-DP+. Интеграция — через REST API с JSON. У Waysim у поставщика предоплаченный баланс, каждая покупка списывает с него закупочную цену. Документацию и ключи передаёт заказчик.

- **Авторизация:** ключ доступа в заголовке запроса; дополнительно поддерживается подпись запросов HMAC-SHA256 секретным ключом — использовать её. Ключи только на сервере.
- **Операции:** список пакетов (код пакета, постоянный идентификатор slug, страна или регион, объём, срок, закупочная цена, признак «можно докупать»); заказ с нашим номером транзакции (для идемпотентности); запрос профилей eSIM по номеру заказа или ICCID; докупка; отмена неиспользованной eSIM; приостановка и возобновление; расход трафика; баланс аккаунта.
- **Заказ асинхронный:** профиль выпускается на SM-DP+ за секунды, после чего приходит вебхук `ORDER_STATUS`, и мы запрашиваем профиль. Если вебхук не пришёл — опрашиваем статус с растущей паузой.
- **Данные профиля:** номер заказа, ICCID, строка активации вида `LPA:1$<адрес SM-DP+>$<код>`, ссылка на QR-код, статусы, общий объём и расход в байтах, срок и единица срока, дата окончания.
- **Статус eSIM** (данные у оператора): Provisioning — создаётся; New — готова к установке; Onboard — установлена, трафика ещё не было; In Use — расходует трафик; USEDUP — трафик закончился; Expired — истёк срок; Suspended —

приостановлена; Canceled — отменена с возвратом; Revoked — отозвана за нарушения, без возврата.

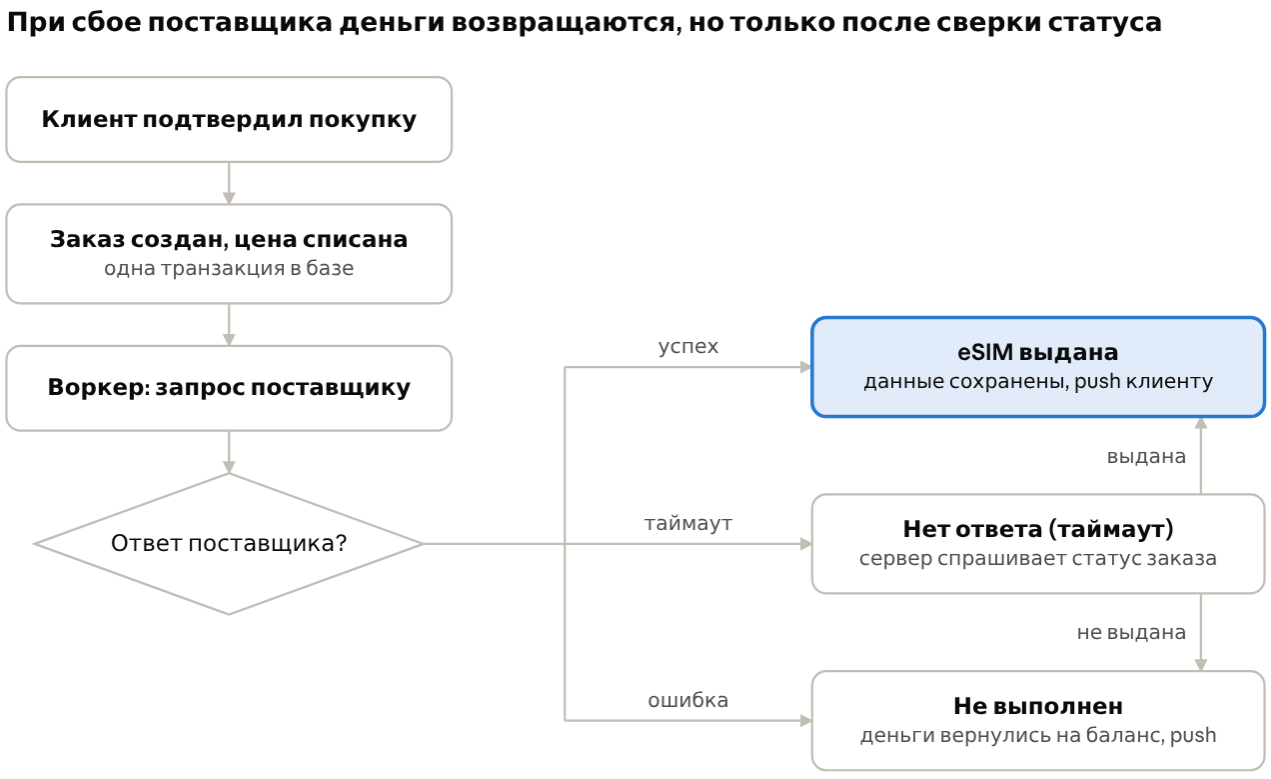
- **Статус SM-DP+** (действия на телефоне, не зависит от первого): Available — ещё не установлена; Download — загружается; Installation — установлена; Enabled — включена; Disabled — выключена; Deleted — удалена с телефона.
- **Соответствие нашим статусам:** New или Available → «Не установлена»; Onboard или Installation → «Установлена»; In Use → «Активна»; USEDUP → «Израсходована»; Expired → «Истекла»; Canceled → «Не выполнен, средства возвращены».
- **Вебхуки** (JSON, адрес прописывается в кабинете поставщика): `ORDER_STATUS` — eSIM готова к загрузке; `ESIM_STATUS` — eSIM начали использовать; `DATA_USAGE` — осталось 100 МБ или меньше; `VALIDITY_USAGE` — остался 1 день. Поля: `notifyType` и `content` с `orderNo`, `transactionId`, `iccid`, статусами, объёмом, расходом, остатком, датой окончания. Обработка идемпотентная; источник проверяется способом из документации, а если подписи нет — секретным токеном в адресе вебхука и белым списком IP.
- **Докупка:** только для eSIM в статусе New или In Use, на истёкшую нельзя; не больше 9 раз на одну eSIM. Пакет с фиксированным объёмом добавляет и гигабайты, и дни; безлимитный — только дни. Часть пакетов не докупается — это видно по признаку в каталоге. Пакет для докупки указывается по slug: код пакета со временем может меняться.
- **Отмена:** через API отменяется только неустановленная eSIM (статус New); деньги возвращаются на баланс Waysim у поставщика вместе со всеми докупками. Установленную eSIM через API не отменить — только через поддержку поставщика.
- **Сроки:** eSIM нужно установить в течение 180 дней после покупки, срок пакета идёт с первого подключения к сети. Удалённую eSIM можно переустановить тем же QR-кодом, пока пакет действует, но только на то же устройство.
- **Установка:** на iOS 17.4+ — Universal Link Apple со строкой LPA; в остальных случаях — QR-код или ручной ввод адреса SM-DP+ и кода.
- **Баланс Waysim у поставщика:** внесённые деньги не возвращаются, поэтому пополнять его под продажи. Ниже порога — уведомление в админке.
- **Ограничения поставщика:** только туристическое использование со смартфона. Роутеры, IoT, долгое использование в одной стране и аномальный расход — повод изменить цену или отключить услугу. Нельзя продавать странам и лицам под санкциями.

- **Надёжность:** таймауты 10–30 с, повторы с растущей паузой, отключение при массовых ошибках; логи без ключей и кодов активации. Разработка и тесты — на тестовых кредитах поставщика.

Наш процесс заказа:

1. Проверки (пакет активен, пользователь не забанен, баланса хватает), затем в одной транзакции — заказ и списание с баланса клиента.
2. Воркер BullMQ отправляет заказ поставщику, ждёт `ORDER_STATUS`, забирает профиль и сохраняет его; клиенту — push «eSIM готова».
3. Ошибка после нескольких повторов — заказ «Не выполнен», деньги возвращаются обратной записью, push клиенту, уведомление админу. Таймаут — сначала запрос статуса заказа у поставщика, и только потом возврат.
4. Каталог синхронизируется по расписанию, розничные цены и всё, что видит клиент, админ задаёт в разделе «eSIM-пакеты» (6.3); пакет, пропавший у поставщика, скрывается в приложении.

5.5 Схема заказа



путь заказа · 3 исхода ответа поставщика

При таймауте деньги возвращаются только после того, как поставщик подтвердил, что eSIM не выдана.

6. Админ-панель

Отдельное веб-приложение на Next.js, адрес admin.waysim.co. Две роли — Админ и Оператор; права проверяются на сервере при каждом запросе, а не только скрываются в интерфейсе.

- **Вход:** логин, пароль не короче 12 символов (Argon2id), обязательная 2FA (TOTP). 5 ошибок — блокировка на 15 минут. Сессия в cookie HttpOnly, Secure, SameSite=Strict, защита от CSRF, выход через 30 минут бездействия. Первый админ создаётся командой на сервере. Рекомендуется доступ по белому списку IP.
- **Шапка:** бейдж роли, тема (светлая по умолчанию или тёмная), язык (русский по умолчанию или английский), кнопка «Выйти».

Возможность	Админ	Оператор
Счётчики пользователей и активных тарифов	Да	Нет
Последние 30, поиск, карточки пользователей и оплат	Да	Да
Бан и разбан	Да	Да
Удаление аккаунта, выдача тарифа	Да	Нет
eSIM-пакеты: цены и параметры тарифов	Да	Нет (раздел скрыт)
Сервер и защита	Да	Нет (рекомендация)
Уведомления, реферальная программа, сотрудники, журнал действий	Да	Нет

6.1 Пользователи

- **Счётчики (админ):** зарегистрированные; активные (есть неистёкший и неизрасходованный пакет); незарегистрированные (гости).
- **Список:** последние 30 по дате и поиск по ID (точно) или почте (от 3 символов), не больше 30 результатов. Лимит 30 — на уровне API.
- **Карточка:** ID, почта, имя, статус, язык, баланс; IP при регистрации и текущий, последняя активность; устройства (модель, ОС, версия приложения); активные тарифы (расход, срок, ICCID); покупки; пополнения с полными деталями; рефералы (ниже); журнал баланса.

- **Детали крипто-оплаты:** сеть, монета, сумма, курс, зачислено в USD, txid со ссылкой на обозреватель блоков, адреса отправителя и получателя, подтверждения, блок, ID инвойса. **PayPal:** order, capture и transaction ID, payer ID, почта и имя плательщика, страна, сумма, комиссия, нетто, статус, возвраты и споры.
- **Действия:** бан и разбан с причиной (сессии завершаются, выданные eSIM продолжают работать); удаление аккаунта (подтверждение вводом ID; личные данные обезличиваются, финансовые записи остаются); выдача тарифа (видна закупочная цена, заказ помечается «выдал админ»).
- **Рефералы клиента:** кто пригласил его самого; сколько людей привёл он — всего, начислено, на проверке, отклонено; список приглашённых: ID, почта, дата регистрации, статус, причина отказа, сумма бонуса, ссылка на карточку. Список листается по 30 записей.

6.2 Оплаты

- **Счётчик (админ):** клиентов с активным тарифом сейчас. Общая сумма продаж за всё время не показывается.
- **Список и поиск:** последние 30 оплат и одно поле поиска — txid или хэш, адреса, ID инвойса; PayPal order, capture или transaction ID, почта плательщика, payer ID; ID и почта пользователя, номер заказа. Не больше 30 результатов.
- **Карточка оплаты:** все детали, хронология статусов, журнал вебхуков. Статусы: Ожидает, Подтверждается, Зачислено, На проверке, Истёк, Отменён, Возврат, Спор.

6.3 eSIM-пакеты (админ)

Кнопка «eSIM-пакеты» в меню админки — все тарифы приложения с ценами и параметрами. Смотреть и менять их может только админ: оператору раздел не виден, а API отвечает ему 403, потому что здесь видны закупочные цены и маржа.

- Список: по 50 строк — страна или регион, тип, объём, дни, закупочная цена, розничная цена, маржа в $ и %, статус. Фильтры по стране, региону, типу и статусу, поиск по стране и коду пакета, сортировка по любому столбцу.
- Статусы: «Опубликован», «Скрыт», «Новый» (появился у поставщика, клиентам не виден), «Пропал у поставщика» (снят с продажи автоматически).
- Карточка пакета: все поля из таблицы ниже, продажи за 30 дней и всего, история изменений — кто, когда, было/стало. Кнопка «Новый тариф»: страна или регион, пакет поставщика, цена и тексты.

Поле	Откуда	Кто меняет
Розничная цена, USD	Админ	Админ
Название и «Сведения о пакете» RU/EN	Админ	Админ
Показ в приложении, порядок в списке	Админ	Админ
Признак «нужна проверка личности»	Админ	Админ
Объём (ГБ), дни, тип (безлимитный или с лимитом ГБ)	Пакет поставщика	Админ — выбором другого пакета поставщика
Страны покрытия, сеть, скорость, раздача интернета, можно ли докупать	Поставщик	Только просмотр
Закупочная цена, код пакета и slug	Поставщик	Только просмотр

Объём, дни и тип нельзя просто переписать: eSIM получит ровно то, что заложено в пакете поставщика, и клиент увидел бы одно, а получил другое. Поэтому при изменении этих полей админка показывает пакеты поставщика для той же страны с нужными параметрами и их закупочные цены; админ выбирает один, и тариф переходит на него. Подходящего пакета нет — сохранить нельзя. У посуточных пакетов, где число дней задаётся в заказе, дни меняются свободно в пределах, которые разрешает поставщик.

Правила для цен:

- Цена вводится в долларах, хранится в центах, маржа пересчитывается сразу при вводе. Маржа ниже порога из настроек (предложение — 20%) — предупреждение и подтверждение; цену ниже закупочной сохранить нельзя.
- Массовое изменение: выбранные пакеты или все по фильтру — наценка в % к закупочной, либо изменение на ±% или ±$, с округлением (например, до $X.99). Перед сохранением — предпросмотр «было → стало» и подтверждение с числом пакетов.
- Новая цена действует для новых заказов сразу, купленные пакеты не меняются. Если цена изменилась, пока клиент в окне подтверждения, сервер отвечает «цена изменилась», и приложение показывает новую цену.

- Синхронизация с поставщиком: изменилась закупочная цена — розничная сама не меняется, админ получает уведомление со списком пакетов, где маржа упала ниже порога. Новые пакеты поставщика попадают в статус «Новый» с предложенной ценой по наценке по умолчанию (настройка) и появляются у клиентов только после публикации.
- Каждое изменение пакета и цены — в журнал действий с «было/стало».

6.4 Сервер и защита (админ)

- Обновление каждые 30–60 с, тревоги дублируются в Telegram или на почту.
- **Серверы** (API, админка, база, очереди): CPU, память, диск, запросы в секунду, время ответа (медиана и p95), ошибки 5xx, версия, задачи в очереди.
- **Внешние сервисы:** поставщик eSIM (доступность, ошибки, наш баланс у него), вебхуки платёжек, почта, push, ИИ.
- **Защита:** срок SSL, срабатывания лимитов и WAF, заблокированные IP, неудачные входы в админку, сотрудники без 2FA (должно быть 0), уязвимые зависимости, дата пентеста.
- **Бэкапы:** последний бэкап и статус, окно восстановления, копия в другом месте, дата проверки восстановления.
- **Пороги тревог:** CPU выше 80% дольше 5 минут, диск больше 85%, ошибок 5xx больше 1%, p95 больше 1 с, сбой бэкапа, SSL меньше 14 дней, низкий баланс у поставщика.
- Метрики — Prometheus и Grafana (или облачный аналог), ошибки — Sentry, логи с маскированием хранятся 30–90 дней.

6.5 Уведомления (админ)

- Заголовок и текст на русском и английском, эмодзи можно, HTML нельзя; куда ведёт нажатие; аудитория (все, зарегистрированные, гости); сейчас или по расписанию.
- Предпросмотр как на iOS и Android, подтверждение с числом получателей, отправка очередью через FCM, не больше 3 рассылок в сутки, история с автором и статистикой.

6.6 Реферальная программа (админ)

- **Включить или выключить** одним переключателем. После выключения приложение при следующем получении настроек убирает баннер, пункт профиля, поле кода при регистрации и push о бонусах; ссылки `waysim.co/r/`

`КОД` открывают приложение без применения кода. Новые приглашения не засчитываются, уже начисленные бонусы остаются, приглашения «На проверке» доводятся до конца.

- **Сумма бонуса** в USD, от $0,50 до $50 с шагом $0,01. Новая сумма действует для друзей, зарегистрированных после изменения: сумма фиксируется в момент регистрации друга.
- **Момент начисления** — после регистрации друга или после его первой покупки; **лимит** бонусов на одного пригласившего в месяц (по умолчанию 10).
- **Статистика за период:** приглашено, начислено, на проверке, отклонено.
- Изменения настроек записываются в журнал действий, раздел доступен только админу.

6.7 Журнал действий

- Записываются все действия сотрудников — вход, просмотр карточки, поиск, бан, удаление, выдача тарифа, изменение пакетов и цен, рассылка — с IP и «было/стало». Изменить или удалить журнал нельзя.

7. Безопасность

Приложение проверяется по OWASP MASVS, бэкенд и админка — по OWASP ASVS уровня 2 и API Security Top 10; перед запуском — внешний пентест. Выпуск только без критических и высоких уязвимостей.

- **Доступ:** каждый запрос проверяет, что ресурс принадлежит пользователю (чужой заказ по ID не открыть); роли админки — на сервере; наружу отдаются только нужные поля.
- **Данные:** только HTTPS (TLS 1.2+, HSTS). База и бэкапы зашифрованы, коды активации и секреты 2FA — дополнительно на уровне полей. OTP-коды и refresh-токены хранятся только как хэши. В логах нет токенов, кодов и платёжных данных.
- **Секреты** — только на сервере (переменные окружения или менеджер секретов), разные для тестовой и боевой среды, с возможностью быстро отозвать.
- **API:** валидация входных данных по схеме (zod), запросы к базе только через ORM или параметризованные; лимиты частоты на вход, OTP, покупки, пополнения и ИИ-чат; лимит размера запроса; белый список CORS.

- **Вебхуки:** проверка подписи, защита от повторной отправки, деньги зачисляются только после повторной проверки платежа у платёжного сервиса.
- **Приложение (Flutter):** токены только в `flutter_secure_storage`; Firebase App Check на регистрацию, рефералку и покупки; релизная сборка с `--obfuscate --split-debug-info` и без отладочных логов; на root и jailbreak — предупреждение и без реферальных бонусов.
- **Админка:** обязательная 2FA, заголовки безопасности (Content-Security-Policy и другие), WAF.
- **Инфраструктура:** Docker, снаружи открыт только порт 443 через NGINX; база и Redis во внутренней сети; SSH только по ключам; контейнеры не от root; защита от DDoS (например, Cloudflare).
- **Бэкапы:** ежедневно плюс восстановление на любой момент за 7–30 дней; шифрование; копия в другом регионе; проверка восстановления раз в месяц. Цель — потеря данных не больше 15 минут, восстановление не дольше 4 часов.
- **По условиям поставщика:** нельзя продавать странам и лицам под санкциями США, ЕС, Великобритании и Гонконга — нужны ограничения по стране при регистрации и оплате. Согласия и уведомления об обработке персональных данных — на нас (политика конфиденциальности). Тарифы — только для туристов со смартфоном: без роутеров и IoT, иначе поставщик может поднять цены или отключить услугу.
- **Режим обслуживания:** флаг, который временно останавливает покупки и пополнения при инциденте.

8. Код, тесты, выпуск

Три проекта — `mobile` (Flutter), `api` (Node.js), `admin` (Next.js) — с общим контрактом OpenAPI. Обязательны тесты на деньги, заказы и рефералку и автоматические проверки при каждом изменении.

- **Flutter:** структура по фичам (data, domain, presentation), Riverpod, go_router, dio с перехватчиком токенов, модели через freezed и json_serializable, клиент API генерируется из OpenAPI. Бизнес-логики в виджетах нет. Линтер `flutter_lints` или `very_good_analysis`. Ошибки — в Crashlytics или Sentry.
- **Node.js:** TypeScript в строгом режиме, без `any`; слои контроллеры → сервисы → работа с базой; миграции с откатом (Prisma или Knex); ESLint и Prettier.

- **Тесты:** модульные — баланс и журнал, заказы, реферaлка, генератор ID (покрытие этих модулей не меньше 80%); интеграционные API с тестовой базой — вход, покупка, пополнение, повторные вебхуки, права ролей; во Flutter — unit- и widget-тесты и `integration_test` на ключевые сценарии; админка — Playwright на права ролей; нагрузочный тест — выдержать нагрузку в 10 раз выше ожидаемого пика.
- **Окружения:** локальное, staging (тестовые кредиты поставщика, sandbox PayPal) и боевое.
- **CI/CD** (GitHub Actions или Codemagic): линтер, тесты, сборка, проверка зависимостей на уязвимости; выкатка в бой — после ручного подтверждения. Приложение — через TestFlight и внутреннее тестирование Google Play.
- **Передача:** README, `.env.example`, OpenAPI, инструкции по развёртыванию, восстановлению из бэкапа и смене ключей. Все аккаунты — Apple, Google, Firebase, облако, домен, кабинет поставщика, платёжки — оформлены на заказчика.

9. Этапы, материалы, открытые вопросы

Работа идёт в 8 этапов, каждый принимается на staging. Сроки команда даёт после изучения ТЗ.

№	Этап	Готово, когда
0	Архитектура, схема базы, OpenAPI, макеты в Figma (две темы)	Заказчик утвердил
1	Ядро бэкенда: вход, ID, баланс и журнал, каталог	Работает на staging, тесты зелёные
2	Приложение на Flutter: все экраны, затем реальный API	Сценарии раздела 4 проходят на iOS и Android
3	Поставщик eSIM: заказ, вебхуки, установка, расход, докупка	Покупка на тестовых кредитах, автовозврат при сбое
4	Платежи: PayPal и крипта, вебхуки, сверка	Повторный вебхук не зачисляет дважды
5	Админка: роли, разделы, журнал	Оператор не может сделать запрещённое даже через API
6	Реферaлка, ИИ-чат, push и рассылки	Проверки работают, рассылка доходит

№	Этап	Готово, когда
7	Безопасность и запуск	Пентест без критичных уязвимостей, приложение в App Store и Google Play

Заказчик передаёт: ключи API поставщика и его документацию (кабинет поставщика остаётся у заказчика, адрес вебхуков заказчик прописывает сам), розничные цены, тексты «Сведения о пакете», данные PayPal и крипто-процессинга, 6 юридических документов на RU и EN, тексты и картинки баннеров, почту поддержки, FAQ для ИИ, логотип и иконку, аккаунты Apple Developer и Google Play, доступ к DNS waysim.co, проект Firebase.

Открытые вопросы

- [ ] Шаг «Как к вам обращаться?» после регистрации — подходит?
- [ ] Реферальный бонус — после регистрации друга или после его первой покупки? Это теперь переключатель в админке — нужен вариант по умолчанию. Бонус $3 съедает всю прибыль с дешёвого пакета.
- [ ] Формат ID после Z9999 — AA0000?
- [ ] Права оператора на бан и на раздел «Сервер и защита».
- [ ] Лимиты пополнения и кто платит комиссии платёжек.
- [ ] Возвраты клиентам — только за неустановленные eSIM?
- [ ] Недоплата и переплата криптой — зачислять фактическую сумму или возвращать?
- [ ] Срок хранения IP и других личных данных.
- [ ] Админка на Next.js (full-stack разработчик) или на Flutter Web (мобильный)?
- [ ] Риск: правила оплаты App Store и Google Play для внутреннего баланса и криптовалюты — проверить до разработки платежей.